

How Criminal Plan offenses

- Cybercriminal use the internet for illegal activities to store data, contacts, account information, etc.
- People who commit cybercrimes are known as “Crackers”.

Hackers, Crackers and Phreakers

- A hacker is a person with strong interest in computers who enjoys learning and experimenting with them. Hackers are usually very talented, smart people who understand computers better than others.

Brute force hacking

- It is a technique used to find passwords or encryption keys. Brute force hacking involves trying every possible combination of letters, numbers, etc until the code is broken.

Cracker

- A cracker is a person who breaks into computers. Crackers should not be confused with hackers. The term cracker is usually connected to computer criminals.

Cracking

- It is the act of breaking into computers. Cracking is popular, growing subject on the internet. Many sites are devoted to supplying crackers with programs that allow them to crack computers.

Phreaking

- This is the notorious art of breaking into communication system. Phreaking sites are popular among crackers and other criminals.

How Criminals plan the attacks

- Criminals use many methods and tools to locate weakness(vulnerability) of their target.
- Criminals plan passive and active attacks.
- Active attacks are usually used to alter the system whereas passive attacks attempt to gain information about the target.
- In addition to the active and passive categories, attacks can be categorized as either inside or outside.

Inside Attack

- An attack originating and/or attempted within the security perimeter of an organization is an inside attack.
- It is usually attempted by an “insider” who gains access to more resources than expected.

Outside Attack

- An outside attack is attempted by a source outside the security perimeter.
- It may be attempted by an insider and/or an outsider.
- It is attempted through the Internet or a remote access connection.

Phases involved in planning cybercrime

1. Reconnaissance (information gathering) is the first phase and is treated as passive attacks.
2. Scanning the gathered information for the validity of the information as well as to identify the existing weakness.
3. Launching an attack.

Phase 1

- The meaning of Reconnaissance is an act of reconnoitering – explore, often with the goal of finding something or somebody.
- Reconnaissance phase begins with “Footprinting”.
- Footprinting is the preparation toward preattack phase.

Continue...

- Footprinting gives an overview about system weakness and provides a judgment about “**How to break this?**”.
- The objective of this phase is to understand the system, its networking ports and services, and any other aspects of its security.

● Passive Attack :

- In computer security, attempt to steal information stored in a system by electronic wiretapping or similar means.
Although, in contrast to active attack, passive attack does not attempt to interfere with the stored data, it may still constitute a criminal offense.

- A passive attack involves gathering information about a target without his/her knowledge. Information can be gathered from :
 - ✦ It is usually done using Internet searches or by Googling. They use Google Earth to locate information about employees.
 - ✦ Surfing online community groups like orkut/facebook will prove useful to gain the information about an individual.

Continue...

- ✦ Organization's website may provide a personnel directory or information about key employees.
- ✦ Blogs, newgroups, press releases, etc. are generally used as the mediums to gain information about the company or employee.
- ✦ Going through the job postings in particular job profiles for technical persons.
- Network sniffing is another means of passive attack to yield useful information such as IP, hidden servers or networks.

Tools used for Passive Attack

- Google Earth
- WHOIS
- Nslookup (name server lookup)
- Dnsstuff
- eMailTrackerPro
- Website Watcher

- Active Attack

- In computer security, persistent attempt to introduce invalid data into a system, and/or to damage or destroy data already stored in it. In many countries, it is a criminal offense to attempt any such action.

Port Scanning

- A port is place where information goes into and out of a computer.
- Ports are entry/exit points that any computer has, to be able to communicate with external machines.
- Each computer is enabled with three or more external ports.
- Port scanning is an act of systematically scanning a computer's ports.

Phase – 2 : Scanning and Scrutinizing gathered information

- Scanning is a key step to examine intelligently while gathering information about the target. The objectives of scanning are as follows :
 - Port Scanning :
 - ✦ Identify open/close ports and services.
 - Network scanning :
 - ✦ Understand IP addresses and related information about the computer network system.
 - Vulnerability scanning :
 - ✦ Understand the existing weaknesses in the system.

- The scrutinizing (inspecting) phase is called “enumeration” (listing) in the hacking world.
- The objective behind this step is to identify :
 - The valid user accounts or groups;
 - Network resources and/or shared resources;
 - OS and different applications that are running on the OS.
- **Note :** *Usually most of the attackers consume 90% of the time in scanning, scrutinizing and gathering information on a target and 10% of the time in launching the attack.*

Phase 3 : Attack

- The attack is launched using the following steps :
 - Crack the password;
 - Exploit the privileges;
 - Execute the malicious command/applications;
 - Hide the files (if required);
 - Cover the tracks – delete the access logs, so that there is no trail illicit activity.

Social Engineering

- Social engineering is the “technique to influence” people to obtain the information.
- It is generally observed that people are the weak link in security and this principle makes social engineering possible.
- Social engineering involves gaining sensitive information or unauthorized access privileges by building inappropriate trust relationships with insiders.

Classification of Social Engineering

- Human Based Social Engineering
- Computer Based Social Engineering

Human Based Social Engineering

- Human based social engineering refers to person-to-person interaction to get information.
 - Impersonating an employee or valid user
 - Posing as an important user
 - Using a third person
 - Calling technical support
 - Shoulder surfing
 - Dumpster diving

Computer Based Social Engineering

- Computer based social engineering refers to an attempt made to get the required information by using computer software/internet.
 - Fake E-mail
 - E-mail attachments
 - Pop-up windows

Cyberstalking

- Stalking is an “*act or process of following victim silently – trying to approach somebody or something*”
- Cyberstalking has been defined as the use of information and communications technology of individuals to harass another individual.

Types of Stalkers

- There are primarily two types of stalkers.
 - Online stalkers
 - Offline stalkers
- Online stalkers :
 - They aim to start the interaction with the victim directly with the help of the internet (email/Chat Room).
 - The stalker makes sure that the victim recognizes the attack attempted on him/her.
 - The stalker can make use of a third party to harass the victim.

● Offline stalkers :

- The stalker may begin the attack using traditional methods such as following victim, watching the daily routine of the victim, etc.
- For ex. Use of community sites, newsgroups, social websites, personal websites.
- The victim is not aware that the Internet has been used to achieve an attack against them.

Cases reported on Cyberstalking

- The majority of cyberstalking are men and the majority of their victims are women.
- In many cases, the cyberstalker is ex-lover, ex-spouse, boss/subordinate, and neighbor.
- There also have been cases about strangers who are cyberstalkers.

How Stalking works?

- Personal information gathering about the victim;
- Establish a contact with victim through telephone/cell phone. Once the contact is established, the stalker may make calls to the victim to harass.
- Stalkers always establish a contact with victim through e-mail.

- The stalker may post the victim's personal information as sex workers' service or dating service. The stalker will use bad/attractive language to invite the interested persons.
- Whosoever comes across the information, starts calling victim and asking for sexual services or relationship.
- Some stalkers subscribe the e-mail account of the victim to innumerable pornographic and sex sites.

Real Life Example

- The indian police have registered first case of cyberstalking in Delhi.
- Mrs. Joshi received almost 40 calls in 3 days mostly at odd hours.
- Mrs. Joshi decided to register a complaint with Delhi police.
- A person was using her ID to chat over the Internet at the website www.mirc.com.

Cybercafe and Cybercrimes

- In February 2009 survey, 90% of the audience across eight cities and 3500 cafes were male and in the age group of 15-35 years;
- 52% were graduates and postgraduates
- Almost 50% were students.
- In India, cybercafes are known to be used for either real or false terrorist communication.

- Cybercafe hold two types of risks :
 1. We do not know what programs are installed on the computer like keyloggers or spyware.
 2. Over the shoulder peeping can enable others to find out your passwords.
- Cybercriminals prefer cybercafes to carry out their activities.
- A recent survey conducted in one of the metropolitan cities in India reveals the following facts :

1. Pirated softwares are installed in all the computers.
2. Antivirus was not updated with latest patch.
3. Several cybercafes has installed “Deep Freeze” to protect computer which helps cybercriminals.
4. Annual Maintenance Contract (AMC) was not found for servicing of the computer.
5. Pornographical websites were not blocked.

6. Cybercafe owner have very less awareness about IT security.
7. Cybercafe association or State Police do not seem to conduct periodic visits to cybercafe.

Security tips for cybercafe

- Always Logout
 - While checking email or logging in for chatting, always click logout/sign out.
- Stay with the computer
 - While surfing, don't leave the system unattended for any period of time.
- Clear history and temporary files
 - Before browsing deselect **AutoComplete** option. Browser -> Tools -> Internet options -> Content tab.
 - Tools -> Internet Option -> General Tab -> Temporary Internet Files -> Delete files and then Delete Cookies.

- **Be alert**
 - One have to be alert for snooping over the shoulder.
- **Avoid online financial transactions**
 - One should avoid online banking, shopping, etc.
 - Don't provide sensitive information such as credit card number or bank account details.
- **Change Passwords / Virtual Keyboard**
 - Change password after completion of transaction.
 - Almost every bank websites provide virtual keyboard.
- **Security Warnings**
 - Follow security warning while accessing any bank websites.

Botnet

- The meaning of botnet is “***an automated program for doing some particular task, over a network***”.
- Botnet term is used for collection of software that run autonomously and automatically.
- Botnets are exploited for various purposes, including denial-of-service attacks, creation or misuse of SMTP mail relays for spam, click fraud, and financial information such as credit card numbers.

- In short, a botnet is a network of computers infected with a malicious program that allows cybercriminals to control the infected machines remotely without the users' knowledge.
- A Botnet is also called a ***zombie network***.



How a botnet is created and used

- A botnet operator sends out viruses or worms, infecting ordinary users' computers, whose payload is a malicious application—the *bot*.
- The *bot* on the infected PC logs into a particular C&C server (often an IRC server, but, in some cases a web server).

- A spammer purchases the services of the botnet from the operator.
- The spammer provides the spam messages to the operator, who instructs the compromised machines via the IRC server, causing them to send out spam messages.

Use of Botnet

- If someone wants to start a business and has no programming skills, there are plenty of “Bot for Sale” offers on forums.
- Encryption of these program’s code can also be ordered to protect them from detection by antivirus.

Botnet
creation

Botnet
renting

Botnet selling

Ddos attacks

Spam attacks

Malware and
Adware
installation

Stealing
confidential
information

Phishing
attacks

Spamdexing

Selling credit
card and
bank account
details

Selling
personal
identity
information

Selling
internet
services and
shops
account

Points to secure the system :

- Use antivirus and anti-Spyware software and keep it up-to-date.
- Set the OS to download and install security patches automatically.
- Use a firewall to protect the system from hacking attacks while it is connected on the internet.
- Disconnected from the internet when you are away from your computer.

- Downloading the freeware only from websites that are known and trustworthy.
- Check regularly the folders in the mail box for those messages you did not send.
- Take an immediate action if your system is infected.

Attack Vector

- An attack vector is a path by which an attacker can gain access to a computer or to a network server to deliver a payload.
- Attack vectors enable attackers to exploit system vulnerability.
- Attack vectors include viruses, e-mail attachments, webpages, pop-up windows, instant messages, and chat rooms.

- The most common malicious payloads are viruses, trojan horses, worms and spyware.
- Payload means the malicious activity that the attack performs.
- **How attack launched ?**
 - Attack by e-mail
 - Attachment
 - Attack by deception
 - Hackers
 - Heedless guests
 - Attack of worms
 - Malicious macros
 - Virues

Cybercrime and Cloud Computing



- Prime area of the risk in cloud computing is protection of user data.
- Risk associated with cloud computing environment are :

Risk	How to Remediate the Risk?
Any data processed outside the organization brings with it an inherent level of risk.	Customer should obtain as much information as he/she can about the service provider.
Cloud computing service providers are not able and/or not willing to undergo external assessments.	The organization is entirely responsible for the security and integrity of their own data, even when it is held by a service provider.
The organizations that are obtaining cloud computing services may not be aware about where the data is hosted and may not even know in which country it is hosted.	Organization should ensure that the service provider is committed to obey local privacy requirements on behalf of the organization to store and process the data in the specific jurisdictions.

As the data will be stored under stored environment, encryption mechanism should be strong enough to segregate (separate) the data from another organization, whose data are also stored under the same server.	Organization should be aware of the arrangements made by the service provider about segregation of the data. The service provider should display encryption schemes.
Business continuity in case of any disaster.	Service provider have to provide complete restoration of data within minimum timeframe.

Due to complex IT environment and several customer logging in and logging out of the hosts, it becomes difficult to trace inappropriate and illegal activity.	Organization should enforce the provider to provide security violation logs at frequent intervals.
In case of any major change in the cloud computing service provider, the service provided is at the stake.	Organization should ensure getting their data in case of such major event.

Questions



- Explain difference between passive and active attack.
- What is social engineering? Explain each type of social engineering in detail.
- What is cyberstalking?
- What is botnet? How it works?
 - OR
- How do viruses get disseminated? Explain with diagram.

- What is Attack Vector? How different attacks launched with attack vector.
- What is cloud computing? List and explain type of services of cloud computing?
- What is cloud computing? Explain types of cloud and also list the advantages of cloud computing.
- Explain cloud computing and cybercrime.

Book: Cyber Security

Understanding Cyber Crimes, Computer
Forensics and Legal Perspective

- By Nina Godbole, Sunit Belapure

Chapter 4

Tools and Methods Used in Cybercrime

Content

- ◉ Introduction
- ◉ Proxy Server and Anonymizers
- ◉ Phishing
- ◉ Password Cracking
- ◉ Keyloggers and Spywares
- ◉ Virus and Worms
- ◉ Trojan Horses and Backdoors
- ◉ Steganography
- ◉ DoS and DDoS Attacks
- ◉ SQL Injection
- ◉ Buffer Overflow
- ◉ Attacks on Wireless Networks

Introduction

- ◉ Various tools and techniques used to launch attacks against the target
 - Scareware
 - Malvertising
 - Clickjacking
 - Ransomware

Cont...

- Basic stages of an attack are described here to understand how an attacker can compromise a network here:
 1. Initial uncovering:
 - Two steps involved: 1) Reconnaissance
2) Attacker uncovers information
 2. Network Probe
 3. Crossing the line toward E-crime
 4. Capturing the network
 5. Grab the data
 6. Covering tracks

Proxy Server and Anonymizer

- Proxy server is computer on a network which acts as an intermediary for connections with other computers on that network
- 1st attacker connects to proxy server
- Proxy server can allow an attacker to hide ID

● Purpose of proxy server:

- Keep the system behind the curtain
- Speed up access to resource
- Specialized proxy servers are used to filter unwanted content such as advertisement
- Proxy server can be used as IP address multiplexer to enable to connect no. of computers on the Internet

Cont...

- An anonymizer or an anonymous proxy is a tool that attempts to make activity on the Internet untraceable
- It accesses the Internet user's behalf, protecting personal information by hiding the source computer's identifying information

Phishing

- ◉ Introduced in 1996
- ◉ Fake E-Mail using other reputed companies or individual's identity
- ◉ People associate phishing with E-Mail message that spoof or mimic banks, credit card companies or other business such as Amazon and eBay

How Phishing works?

Phishers works as follows

- Planning: decide the target & determine how to get E-Mail address
- Setup: create methods for delivering the message & to collect the data about the target
- Attack: sends a phony message that appears to be from a reputable source
- Collection: record the information of victims entering into web pages or pop-up window
- Identify theft and fraud: use information that they have gathered to make illegal purchases and commit fraud

Virus and Worms

- Computer virus is a program that can “infect” legitimate programs by modifying them to include a possibly “evolved” copy of itself.
- Viruses spread themselves, without the knowledge or permission of the users
- Contains malicious instructions
- A virus can start on event driven effects, time driven effects, or can occur random.

Cont...

- Viruses can take some actions:
 - Display a message to prompt an action into which viruses enter
 - Scramble data on hard disk
 - Delete files inside the system
 - Cause erratic screen behavior
 - Halt the PC
 - Replicate themselves

How virus spread

Figures 4.1–4.3 explain how viruses spread (a) through the Internet, (b) through a stand-alone computer system and (c) through local networks.

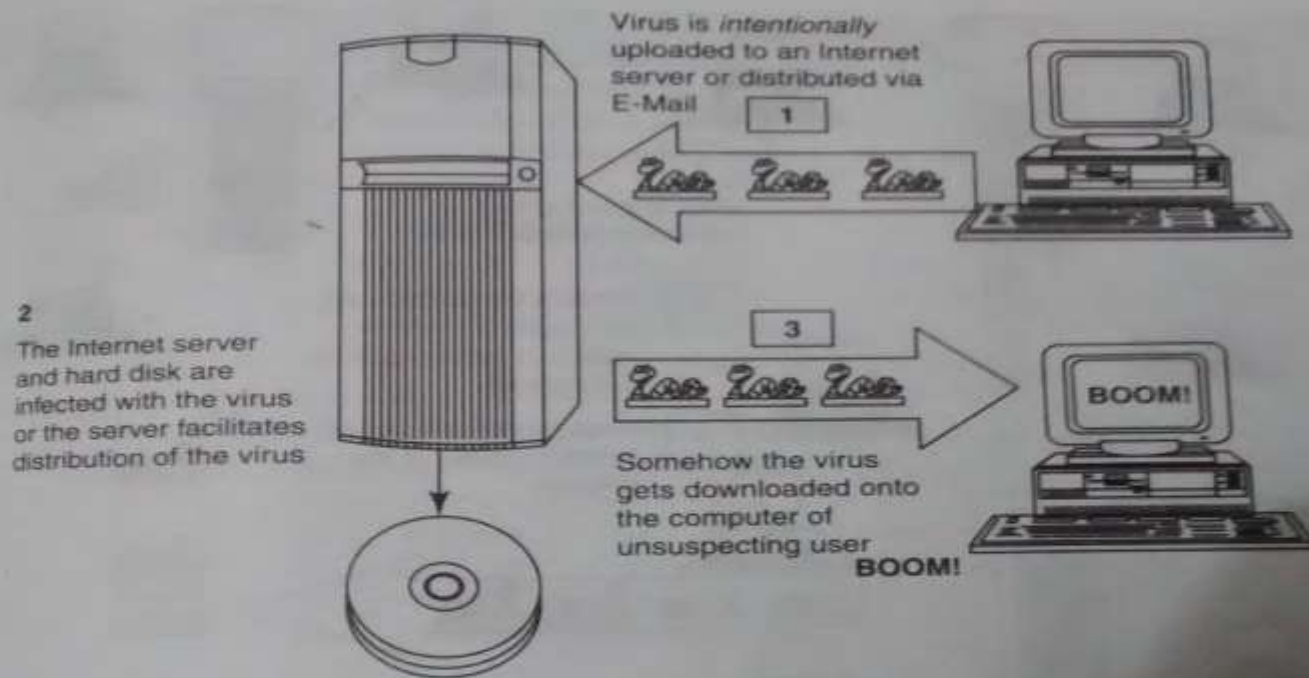


Figure 4.1 | Virus spreads through the Internet.

Cont...

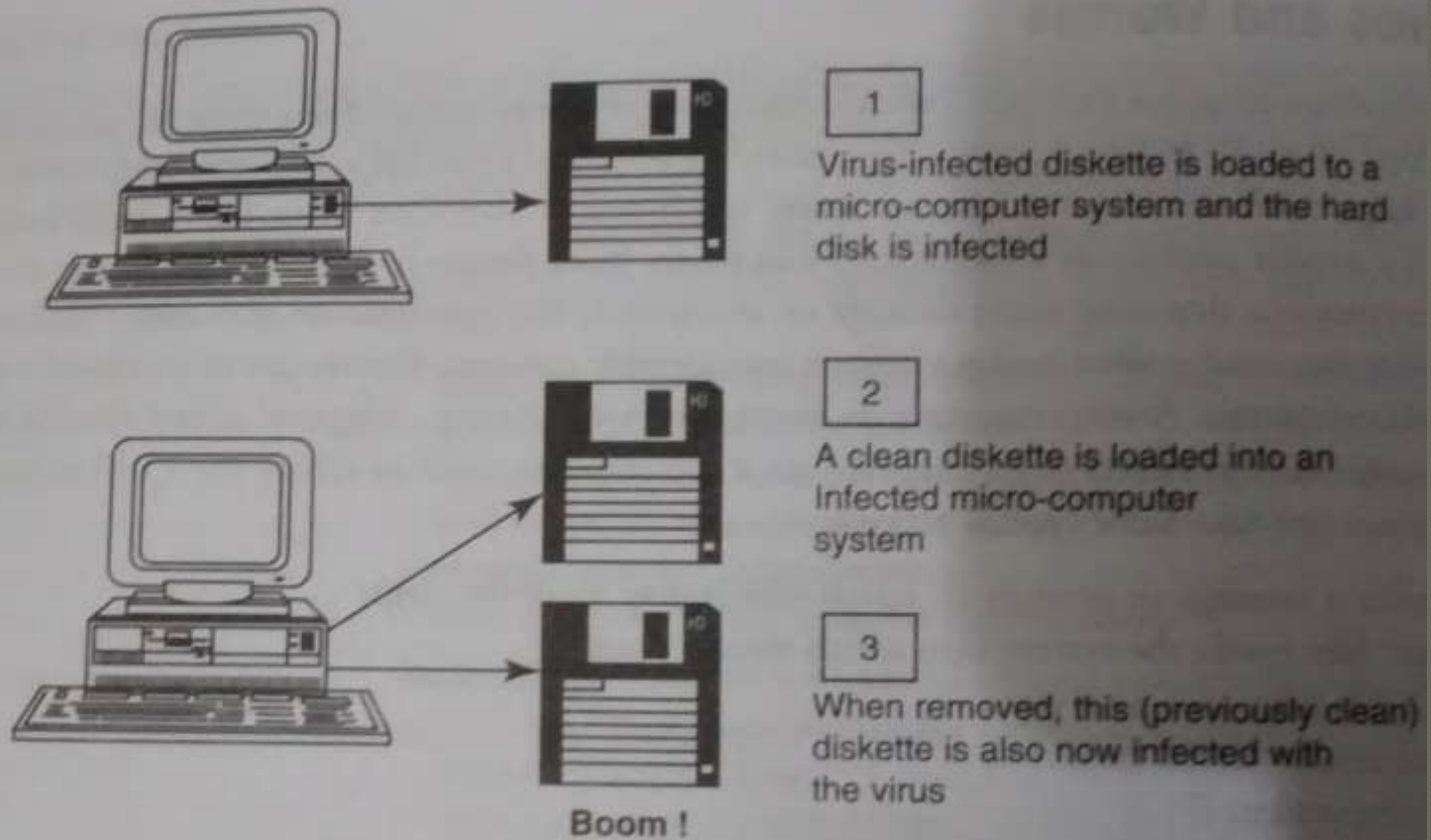


Figure 4.2 | Virus spreads through stand-alone system.

Cont...

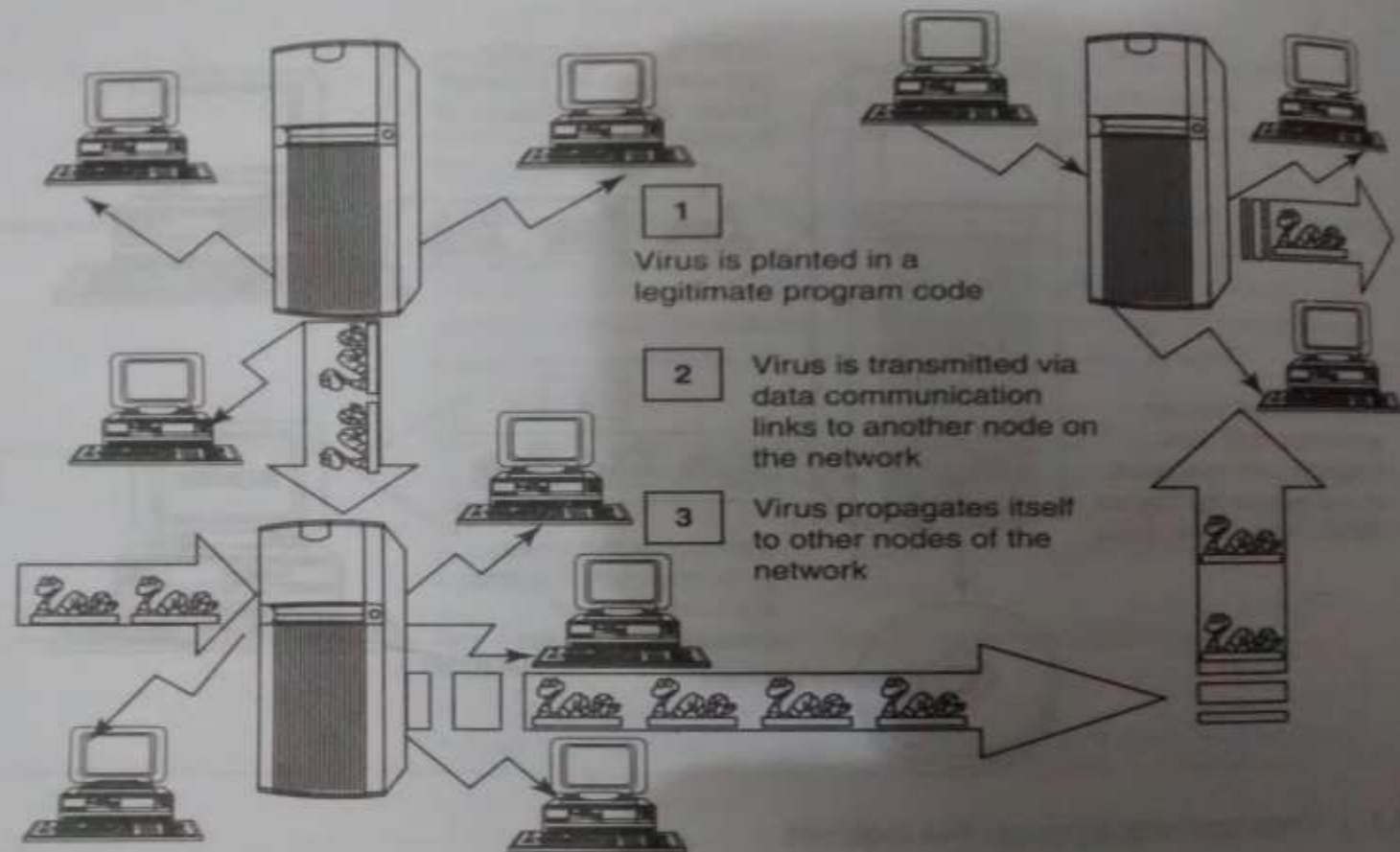


Figure 4.3 | Virus spreads through local networks.

Cont...

- True virus can only spread from one system to another
- A worm spreads itself automatically to other computers through networks by exploiting security vulnerabilities

Difference between virus and worm

Table 4.7 | Difference between computer virus and worm

Sr. No.	Facet	Virus	Worm
1	Different types	Stealth virus, self-modified virus, encryption with variable key virus, polymorphic code virus, metamorphic code virus	E-Mail worms, instant messaging worms, Internet worms, IRC worms, file-sharing networks worms
2	Spread mode	Needs a host program to spread	Self, without user intervention
3	What is it?	A computer virus is a software program that can copy itself and infect the data or information, without the users' knowledge. However, to spread to another computer, it needs a host program that carries the virus	A computer worm is a software program, self-replicating in nature, which spreads through a network. It can send copies through the network with or without user intervention
4	Inception	The creeper virus was considered as the first known virus. It was spread through ARPANET in the early 1970s. It spreads through the TENEX OS and uses connected modem to dial out to a remote computer and infect it.	The name worm originated from The Shockwave Rider, a science fiction novel published in 1975 by John Brunner. Later researchers John F Shock and Jon A Hupp at Xerox PARC published a paper in 1982, <i>The Worm Programs</i> and after that the name was adopted
5	Prevalence	Over 100,000 known computer viruses have been there though not all have attacked computers (till 2005)	Prevalence for virus is very high as against moderate prevalence for a worm.

Types of Viruses

Categorized based on attacks on various element of the system

- Boot sector viruses:

- Infects the storage media on which OS is stored and which is used to start the computer system
- Spread to other systems when shared infected disks & pirated software(s) are used

- Program viruses:

- Active when program file(usually with extensions .bin, .com, .exe, .ovl, .drv) is executed
- Makes copy of itself

Cont...

◉ Multipartite Viruses:

- Hybrid of a boot sector and program viruses

◉ Stealth viruses:

- Masks itself
- Antivirus S/W also cannot detect
- Alter its file system and hide in the computer memory to remain in the system undetected
- 1st computer virus named as Brain

Cont...

● Polymorphic viruses:

- Like “chameleon” that changes its virus signature (i.e., binary pattern) every time it spread through the system (i.e., multiplies & infect a new file)
- Polymorphic generators are routines that can be linked with the existing viruses
- Generators are not viruses but purpose to hide actual viruses under the cloak of polymorphism

Cont...

- Macroviruses:

- Infect documents produced by victims computer

- Active X and Java control:

Trojan Horses

- Trojan horse is a program in which malicious or harmful code is contained inside apparently harmless programming or data in such a way that it can get control and cause harm
- Get into system from no. of ways, including web browser, via E-Mail, or with S/W download from the Internet

Cont..

- Trojans do not replicate themselves but they can be equally destructive
- Examples of threats by Trojans:
 - Erase, overwrite or corrupt data on computer
 - Help to spread other malware
 - Deactivate or interfere with antivirus and firewall
 - Allow to remote access to your computer
 - Upload and download files without user knowledge
 - Gather E-Mail address and use them for spam
 - Slow down , restart or shutdown the system
 - Reinstall themselves after being disable
 - Disable task manager or control panel
 - Copy fake links to false websites, display porno sites, play sounds/videos and display images
 - Log keystrokes to steal info such as password or credit card no.

Backdoor

- It means of access to a computer program that bypass security mechanisms
- Programmer use it for troubleshooting
- Attackers often use backdoors that they detect or install themselves as part of an exploit
- Works in background and hides from user
- Most dangerous parasite, as it allows a malicious person to perform any possible action
- Programmer sometimes leave such backdoor in their software for diagnostic and troubleshooting purpose. Attacker discover these undocumented features and use them

What a backdoor does?

- Allow an attacker to create, delete, rename, copy or edit any file; change any system setting, alter window registry; run, control and terminate application; install arbitrary software
- To control computer hardware devices, modify related setting, shutdown or restart a computer without asking for user permission
- Steals sensitive personal information, logs user activity, tracks web browsing habits
- Record keystrokes
- Sends all gathered data to predefined E-Mail address
- Infects files, corrupts installed app & damage entire system
- Distributes infected files to remote computers and perform attack against hacker-defined remote hosts
- Installed hidden FTP server that can be used by malicious person
- Degrade Internet connection speed and overall system performance
- Provide uninstall feature and hides processes, files and other objects to complicate its removal as much as possible

Examples of Backdoor Trojans

- ◉ Back orifice:
 - Enable user to control a computer running the Microsoft Windows OS from remote location
- ◉ Bifrost:
 - Infect Windows 95 through Vista
- ◉ SAP backdoors
- ◉ Onapsis Bizploit

How to protect from Trojan Horses and Backdoors

- ◉ Stay away from suspect websites/ web links
- ◉ Surf on the web cautiously
- ◉ Install antivirus/ Trojan remover software

Steganography

- ◉ Greek word that means “Sheltered writing”
- ◉ Comes from 2 Greek words:
 - Steganos means “covered”
 - Graphein means “to write” or “concealed writing”
- ◉ Steganalysis:
 - Detecting messages that are hidden in images, audio/video files using steganography

Dos and DDoS Attack

- An attempt to make a computer resources unavailable to its intended users
- DoS attack:
 - Attacker floods the BW of the victim's N/W or fills his E-Mail box with Spam mail depriving him of the services he is entitled to access or provide
 - Attacker typically target sites or services hosted on high-profile web servers such as banks, credit card payment gateways, mobile phone networks and even root name servers

DoS Attack

- Buffer overflow technique is employed to commit such kind of criminal attack
- Attacker spoofs the IP address and floods the N/W of victim with repeated requests
- As the IP address is fake, the victim machine keeps waiting for response from the attacker's machine for each request
- This consumes the BW of the N/W which then fails to server the legitimate responses and ultimately breaks down

Symptoms of DoS attack

- US Computer Emergency Response defines it:

- Unusually slow n/w performance(opening file or accessing websites)
- Unavailability of a particular website
- Inability to access any website
- Dramatic increase in the no. of Spam E-Mails received

What DoS attack does?

- ◉ Goal of DoS is not to gain unauthorized access to systems or data, but to prevents intended users of a service from using it.
- ◉ Activity done by DoS
 - Flood a n/w with traffic
 - Disrupt connection between 2 systems
 - Prevent a particular individual from accessing service
 - Disrupt service to a specific system or person

Classification of DoS attacks

- Bandwidth attacks

- Consuming all the bandwidth of site

- Logic attack

- Exploit vulnerabilities in n/w s/w such as web server or TCP/IP stack

- Protocol attacks

- Exploit specific feature or implementation bug of some protocol installed at victim's system to consume excess amount of its resources

- Unintentional DoS attack

Types or levels of DoS attacks

1. Flood attack: (Ping flood)

- Attacker sending no. of ping packets, using “ping” command, which result into more traffic than victim can handle
- This requires the attacker to have faster n/w connection than the victim
- Prevention is difficult

2. Ping of death attack:

- Sends oversized ICMP packets
- Receiving this packet, will crash, freeze or reboot system

Cont...

3. SYN attack: (TCP SYN flooding)

4. Teardrop attack:

- Attack where fragmented packets are forged to overlap each other when the receiving host tries to reassemble them
- IP's packet fragmentation algo is used to send corrupted packets to confuse the victim and may hang the system
- Windows 3.1x, 95 and NT , Linux versions 2.0.32, 2.1.63 are vulnerable to this attack

5. Smurf attack

- Generating significant computer n/w traffic on victim n/w, using floods via spoofed broadcast ping message
- Attack consists of a host sending ICMP echo request to n/w broadcast ping address
- Every host receive this packet & send back ICMP echo response
- Internet relay chat(IRC)servers are primarily victim of smurf attack

Cont...

6. Nuke:

- An old DoS attack against computer n/w s consisting of fragmented or otherwise invalid ICMP packets sent to target
- Achieved by using a modified ping utility to repeatedly send this corrupt data, thus slowing down the affected computer until it comes to complete stop
- Eg. WinNuke, which is exploited the vulnerability in the NetBIOS handler in windows 95. A string of out-of-band data was sent to TCP port 139 of victim's machine, causing it to lock up and display Blue Screen Of Death(BSOD)

Tools used to launch DoS attack

- ◉ Jolt2: attack against window based machine—consume 100% of CPU time on processing of illegal packets
- ◉ Nemesy: generates random packets of spoofed source IP
- ◉ Targa: used to run 8 different DoS attack
- ◉ Crazy Pinger: send large packets of ICMP
- ◉ SomeTrouble: remote flooder and bomber—developed in Delphi

Blended threat

- It is a more sophisticated attack that bundles some of the worst aspects of viruses, worms, Trojan Horses and Malicious code into one single threat
- Use server & Internet vulnerabilities to initiate, transmit and thereafter spread attack
- Characteristics:
 - Cause harm to the infected system or n/w
 - Propagate using multiple methods as attack may come from multiple point
 - Exploit vulnerability
- Serve multiple attacks in one payload
- To use multiple mode of transport
- Rather than a specific attack on predetermined “.exe” files, it could do multiple malicious acts, such as modify your “.exe” files, HTML files and registry keys

Permanent DoS attack

- ◉ Damages a system so badly that it requires replacement or reinstallation of h/w
- ◉ Pure h/w sabotage
- ◉ Phlashedance is a tool created by Rich Smith who detected and demonstrated PDoS

DDoS Attack

- Attacker use your computer to attack another computer
- By taking advantage of security vulnerabilities or weaknesses, an attacker could take control of your computer, then force your computer to send huge amounts of data to a website or send spam to particular E-Mail addresses
- The attack is “distributed” because the attacker is using multiple computers to launch the DoS attack
- Large no. of zombie systems are synchronized to attack a particular system. Zombie systems are called “secondary victims” and main target is called “primary victim”

How to protect from DoS/DDoS Attack

- ◉ Implement router filter
- ◉ If such filters are available in your system, install patches to guard against TCP SYN flooding
- ◉ Disable any unused or inessential n/w service
- ◉ Observe your system performance and establish baselines for ordinary activity
- ◉ Routinely examine your physical security
- ◉ Use tools to detect changes in configuration info or other files
- ◉ Invest and maintain “hot spares”
- ◉ Invest in redundant and fault-tolerant n/w configuration
- ◉ Establish and maintain regular backup schedules and policies
- ◉ Establish and maintain appropriate password policies

SQL Injection

- It is a code injection technique that exploits a security vulnerability occurring in DB layer of application
- Also known as SQL insertion attacks
- Target the SQL servers
- Objective : “to obtain the info while accessing a DB table that may contain personal info”
- Malicious code is inserted into a web form field or the website’s code to make a system execute a command shell or other arbitrary commands

Steps for SQL Injection

- Attacker looks for the WebPages that allow submitting data, that is login page, search or feedback page etc. Also looks HTML commands such as POST and GET by checking the site's source code
- Checks the source code of HTML and looks for "FORM" tag.
- Inputs a *single quote* under the textbox provided on the webpage to accept the username and password. This checks whether the user-input variable is sanitized or interpreted literally by the server. If the response is an error message then the website is found to be susceptible to an SQL injection
- Uses SQL commands such as SELECT or INSERT

Cont...

- Using SQL injection, attacker can:
 - Obtain some basic info if the purpose of the attack is reconnaissance
 - To get directory listing
 - To ping an IP address
 - May gain access to the DB by obtaining username & password
 - To get user listing: `SELECT * FROM users WHERE name="OR '1'='1'."`
 - Add new data to the DB
 - Execute INSERT command
 - Modify data currently in the DB
 - Execute UPDATE command

Blind SQL Injection

- It is used when a web application is vulnerable to SQL injection but the results of the injection are not visible to the attacker

How to prevent SQL Injection Attack

- Attack occur due to poor websites administration and coding
- Steps to prevent from attack:
 - 1) Input validation:
 - Replace all single quotes to 2 single quotes
 - Sanitize the input: user inputs needs to be checked and cleaned of any characters or strings that could possibly be used maliciously
 - Numeric value should be checked
 - Keep all text boxes and form fields as short as possible to limit the length of user input

Cont...

2) Modify error reports

- SQL error should not be displayed to outside users

3) Other preventions

- SQL server 2000 never be used
- Isolate DB server & web server. Both should reside in different machine
- Extended stored procedures are not used or have unused triggers, stored procedures, user defined functions etc., then these should moved to an isolated server

Buffer Overflow

- Buffer overflow or buffer overrun, is an anomaly(irregularity) where a process stores data in a buffer outside the memory the programmer has set aside for it
- Extra data may result in erratic program behavior, including memory access errors, incorrect result, program termination, or a breach of system security
- It can be triggered by inputs that are designed to execute code or alter way the program operates
- Programming language associated with it including C, C++, which provide no built- in protection against accessing or overwriting data in any part of memory
- Security attack on data integrity

Types of Buffer Overflow

● **Stack- Based Buffer Overflow:**

- occurs when a program writes to memory address on the program's call stack outside the intended data structure- usually fixed length buffer
- Characteristic of stack based programming:
 - “Stack” is a memory space in which automatic variables are allocated
 - Function parameters are allocated on stack & are not automatically initialized by the system
 - Once function has completed its cycle, the reference to the variable in the stack is removed

Cont...

● **Stack- Based Buffer Overflow:**

- The attacker may exploit stack-based buffer overflows to manipulate the program in various ways by overwriting:
 - A local variable that is near the buffer in memory on the stack to change the behavior of the program that may benefit the attacker
 - Return address in a stack. Once the function returns, execution will resume at the return address as specified by the attacker, usually input-filled buffer
 - A function pointer, or execution handler, which is subsequently executed
- Factors that contribute to overcome the exploits are:
 - Null bytes in address
 - Variability in the location of shellcode
 - Differences between environments

Cont...

● NOPs:

- It is an assembly language instruction/ command that effectively does nothing at all
- NOP allows code to execute when the exact value of the instruction pointer is indeterminate
- It helps to know/locate the exact address of the buffer by effectively increasing the size of the target stack buffer area
- Attacker can increase the odds of finding the right memory address by padding his/her code with NOP operation.
- To do this, much larger sections of the stack are corrupted with NOOP machine instruction
- At the end of the attacker- supplied data, after the NOOP, an instruction is placed to perform a relative jump to the top of buffer where shellcode is located

Cont...

● **Heap Buffer Overflow:**

- Occurs in the heap data area and may be introduced accidentally by an application programmer or it may result from a deliberate exploit

How to minimize Buffer Overflow

- ◉ Assessment of secure code manually
- ◉ Disable stack execution
- ◉ Compiler tools
- ◉ Dynamic run-time checks
- ◉ Various tools are used to detect/defend buffer overflow: for eg. StackGuard, ProPolice, LibSafe

Attacks on wireless network

- ◉ In security breaches, penetration of a wireless network through unauthorized access termed as wireless cracking
- ◉ Traditional techniques:
 - Sniffing
 - Spoofing
 - DoS
 - Man-in-the-middle attack
 - Encryption cracking

How to secure the wireless n/w

- Change the default settings of all the equipments/ components of wireless network
- Enable WPA/WEK encryption
- Change the default SSID
- Enable MAC address filtering
- Disable remote login
- Disable SSID broadcast
- Disable the features that are not used in AP
- Avoid providing the n/w a name which can be easily identified
- Connect only to secured wireless n/w
- Upgrade router's firmware periodically
- Assign static IP address to devices
- Enable firewalls on each computer & the router
- Position the router or AP safely
- Turn off the n/w during extended periods when not in use
- Periodic and regular monitor wireless n/w security